

課題④ ポートスキャンのパケット解析

目的

探査段階の中心となるポートスキャンの実習を行う。Nmap で探査中のパケットを調査する。パケットを分析することにより、探査の仕組みを確認する。

事前準備

- server と router の VM を起動する。
- TCP の 3way handshake を調査する。
- ホスト検出、ポートスキャン手法について調査する。
- telnet と SSH の違いについて調査する。

注意事項

- 不用意にインターネット上のサーバに対して Nmap を利用してポートスキャンを行うと、スキャンを受けている側からすれば攻撃を受けているように見える。
演習で構築した VM 以外のサーバ等に対してスキャンしないようにすること。
- 自分で構築、設定していない IP アドレスのマシンへの通信が勝手に発生している場合は、解析に含めなくてよい

操作手順例

(1) Nmap を使ったホスト検出

サブゴール：探査用マシン(server)が属するネットワーク内で動作しているすべてのマシンをリストアップする。

1. server で Wireshark を起動する。
2. 次のコマンドを実行して IP アドレスの指定範囲をスキャンすることで動作しているマシンを探し、IP アドレスを確認する。(Wireshark でパケットを記録すること)

nmap -sn スキャン対象の IP アドレスの範囲 <Enter>

(例えば **nmap -sn 172.20.1.1-254** あるいは **nmap -sn 172.20.1.0/24**
アドレスの範囲はあくまで例です。どの範囲を指定すべきかは各自で考えること。)

解析に時間がかかる場合には、範囲を限定すること。

※ ネットワーク内のすべてのマシンが検出されていることを確認すること。

[解説]：個々のパケットではなく TCP ストリームを解析したい場合には、解析したい TCP ストリーム中のパケットを選択し、右クリックして表示される Follow TCP Stream を選択する。表示されるウィンドウ中の文字色の違いを把握しておくこと。

3. パケット解析した結果 (パケットをキャプチャした結果など) を用いて、OSI 参照モ

デルのどの層で、どのような手順で、どのように、どのような情報が、やり取りされてホスト検出の仕組みが、実現されているかをレポートで報告しなさい。

(2) Nmap を使ったポートスキャン

- ・ サブゴール: 探査用マシン(server)から、(1) ホスト検出で検出された各マシン (以下、被攻撃対象マシン) について順番に調査する
1. telnet と ssh の ポート番号以外の違いで最も大きな違いは何か調査しなさい。
 2. 3 種類のポートスキャンで、OSI 参照モデルのどの層で、どのような手順で、どのように、どのような情報が、やり取りされるか再確認し、整理しなさい。
 3. 被攻撃対象マシン で telnetd と dropbear と ftp が起動していないことを確認する。起動している場合には停止させる。起動しているかどうかは ps コマンドなどで確認すること。
 - ※ ftp は ftp という文字を含むプログラムが動いていないことを確認
 4. 探査用マシン で Wireshark を起動し、以下の 4 つのポートスキャンによって生じた双方向の通信の内容を解析しなさい。
 - ※ 先に以降の手順の意図を把握し、どのような結果を得るべきか考えて、解析をすることを奨める。また、適宜、解析を区切るなど、工夫して実施してもよい。
 - ※ 結果の見通しをよくするためスキャン範囲を telnetd と dropbear が使用するポート番号の前後に絞ってもよいが、関係ないポートも一部含めること
 - ・ TCP connect スキャンを行う。
 - ・ SYN ステルススキャンを行う。
 - ・ UDP スキャンを行う。
 - ・ TCP/IP fingerprinting を用いて OS を判別する。
 5. 被攻撃対象マシン で telnetd と dropbear と ftp を起動させる。dropbear を起動させる際には、オプションとして -R をつけること。FTP server は、既にインストールされているソフト(GUI)を起動させればよい。
 6. telnetd と dropbear と ftp が起動していることを確認する。
 7. 探査用マシン から 被攻撃対象マシン へ telnet および ssh で作成した一般権限ユーザ名でログインできることを確認する。
 8. 探査用マシン から 被攻撃対象マシン へ telnet および ssh でログインする過程で生じた通信の内容を解析し、調査結果より想定される telnet と ssh の最も大きな違いが確認できることを、実験した結果 (比較を含む) を用いて、レポートで報告しなさい。
ヒント: TCP stream でログイン時のパケット内の情報について確認する
 9. 再び、手順 4.を実行し、以前の手順 4.での結果 (出力とキャプチャパケットの面で) と比較し、整理した各ポートスキャンの動作の仕組み (OSI 参照モデルのどの層で、どのよ

うな手順で、どのように、どのような情報が、やり取りされるか) を、実験した結果 (比較を含む) を用いて、レポートで報告しなさい。

10. 手順 8.の比較の内、TCP/IP fingerprinting を用いた OS 判別において、3 つのポートスキャン方法の内、どの方法が利用されているか、実験した結果 (比較を含む) を用いて、レポートで報告しなさい。また、OS の検出結果について違いが起きたか報告しなさい。